

CDK Nag Report

AWS Solutions Checks — Security Agent Demo

Generated: March 03, 2026 at 10:57 AM | Rule Pack: AwsSolutions | Stage: dev

152

TOTAL CHECKS

72

COMPLIANT

80

SUPPRESSED

0

NON-COMPLIANT

Pass Rate (Compliant + Suppressed): 100.0%

Per-Stack Breakdown

Stack	Total	Compliant	Suppressed	Non-Compliant
Backend	109	47	62	0
Frontend	16	15	1	0
Frontend Deployment	24	8	16	0
DNS	3	2	1	0

Non-Compliant Findings (0 unique)

No non-compliant findings. All checks either pass or have documented suppressions.

Suppressed Findings (55 unique)

Rule ID	Stack	Resource	Level	Suppression Reason
AwsSolutions-EC23	Backend	networking/securityGroup/Resource	Error	Security group only allows HTTPS traffic from VPC CIDR block.
AwsSolutions-COG2	Backend	auth/userPool/Resource	Warning	Cognito user pool should not require MFA for demos.
AwsSolutions-COG3	Backend	auth/userPool/Resource	Error	AdvancedSecurityMode is set to depreciate. Using Cognito feature plan's essential security feature.
AwsSolutions-IAM5	Backend	auth/identityPool/AuthenticatedRole/DefaultPolicy/Resource	Error	CDK high-level constructs (grantRead, grantReadWrite, Provider framework) generate scoped wildcard permissions on specific resource ARNs.
AwsSolutions-IAM4	Backend	BucketNotificationsHandler050a0587b7544547bf325f094a3db834/Role/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaBasicExecutionRole] Lambda functions can require managed policies.
AwsSolutions-IAM4	Backend	Custom::CDKBucketDeployment8693BB64968944B69AAFB0CC9EB8756C/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaBasicExecutionRole] Lambda functions can require managed policies.

AwsSolutions-IAM5	Backend	Custom::CDKBucketDeployment8693BB64968944B69AABF0CC9EB8756C/ServiceRole/DefaultPolicy/Resource	Error	CDK high-level constructs (grantRead, grantReadWrite, Provider framework) generate scoped wildcard permissions on specific resource ARNs.
AwsSolutions-L1	Backend	Custom::CDKBucketDeployment8693BB64968944B69AABF0CC9EB8756C/Resource	Error	CDK custom resource providers and auto-delete handlers manage their own Lambda runtimes.
AwsSolutions-RDS3	Backend	database/database/Resource	Error	Multi-AZ not required for demo environment - reduces cost
AwsSolutions-RDS10	Backend	database/database/Resource	Error	Deletion protection disabled for demo environment - allows easy cleanup
AwsSolutions-IAM4	Backend	database/seedFunction/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaBasicExecutionRole] Lambda functions can require managed policies.
AwsSolutions-IAM4	Backend	database/seedFunction/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaVPCLAccessExecutionRole] Lambda functions can require managed policies.
AwsSolutions-L1	Backend	database/seedFunction/Resource	Error	CDK custom resource providers and auto-delete handlers manage their own Lambda runtimes.
AwsSolutions-IAM4	Backend	database/seedProvider/framework-onEvent/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaBasicExecutionRole] Lambda functions can require managed policies.
AwsSolutions-IAM5	Backend	database/seedProvider/framework-onEvent/ServiceRole/DefaultPolicy/Resource	Error	CDK Provider framework appends :* to Lambda ARN for lambda:InvokeFunction to cover all qualifiers.
AwsSolutions-L1	Backend	database/seedProvider/framework-onEvent/Resource	Error	CDK custom resource providers and auto-delete handlers manage their own Lambda runtimes.
AwsSolutions-IAM4	Backend	restApi/restApi/CloudWatchRole/Resource	Error	RestApi requires the AmazonAPIGatewayPushToCloudWatchLogs policy for logging.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-profile/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-profile/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-profile/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-profile/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-profile/{id}/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-profile/{id}/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-comments/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-comments/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.

AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-comments/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-comments/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-search/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-search/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-search/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-search/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-tools/ping/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-tools/ping/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-tools/nslookup/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-tools/nslookup/POST/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-health/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-health/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-xss-page/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-xss-page/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-xss-comments/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-xss-comments/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-APIG4	Backend	restApi/restApi/Default/security-xss-search/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.
AwsSolutions-COG4	Backend	restApi/restApi/Default/security-xss-search/GET/Resource	Error	Security demo endpoints are intentionally unauthenticated to allow pen test scanners to test for vulnerabilities without requiring Cognito JWT tokens.

AwsSolutions-IAM4	Backend	restApi/proxyFunction/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaBasicExecutionRole] Lambda functions can require managed policies.
AwsSolutions-IAM4	Backend	restApi/proxyFunction/ServiceRole/Resource	Error	[Policy::arn::iam::aws:policy/service-role/AWSLambdaVPAccessExecutionRole] Lambda functions can require managed policies.
AwsSolutions-IAM5	Backend	restApi/proxyFunction/ServiceRole/DefaultPolicy/Resource	Error	S3 grantRead generates scoped wildcard actions (s3:GetObject*, s3:GetBucket*, s3:List*) on the CRM images bucket ARN. CloudWatch PutMetricData requires Resource::* per AWS API design.
AwsSolutions-L1	Backend	restApi/proxyFunction/Resource	Error	CDK custom resource providers and auto-delete handlers manage their own Lambda runtimes.
AwsSolutions-CFR1	Frontend	distribution/Resource	Warning	Distribution should be globally accessible.
AwsSolutions-IAM5	Frontend Deployement	staticWebsiteBuild/buildProject/Role/DefaultPolicy/Resource	Error	Wildcard permissions required for S3 sync and CloudFront invalidation
AwsSolutions-IAM4	Frontend Deployement	staticWebsiteBuild/triggerFunction/ServiceRole/Resource	Error	Lambda basic execution role required for logging.
AwsSolutions-L1	Frontend Deployement	staticWebsiteBuild/triggerFunction/Resource	Error	Using Node.js 22, the latest supported runtime.
AwsSolutions-IAM4	Frontend Deployement	staticWebsiteBuild/provider/framework-onEvent/ServiceRole/Resource	Error	Provider framework requires managed policies.
AwsSolutions-IAM5	Frontend Deployement	staticWebsiteBuild/provider/framework-onEvent/ServiceRole/DefaultPolicy/Resource	Error	Provider framework requires wildcard log permissions.
AwsSolutions-L1	Frontend Deployement	staticWebsiteBuild/provider/framework-onEvent/Resource	Error	Provider framework manages its own runtime.
AwsSolutions-IAM5	DNS	NovaDomainServiceRole/DefaultPolicy/Resource	Error	[Resource::*] CDK high-level constructs generate wildcard permissions for custom resource providers, bucket notifications, and auto-delete handlers.